

TASK :1

Understanding Cyber Security Basics & Attack Surface

NAME : MALLADI SIVA SHANKAR

GMAIL ID : msivashankar1607@gmail.com

COLLEGE : ADITYA UNIVERSITY

1. Introduction to Cyber Security

Cyber security refers to the practice of protecting systems, networks, applications, and data from digital attacks. These attacks aim to access, modify, destroy, or steal sensitive information, disrupt services, or damage organizational reputation. With the rapid growth of digital services such as online banking, social media, cloud platforms, and mobile applications, cyber security has become a critical requirement for individuals, organizations, and governments.

The foundation of cyber security is built on three core principles known as the **CIA Triad**:

a) Confidentiality

Confidentiality ensures that sensitive information is accessible only to authorized users.

- **Example (Banking):** User login credentials, account numbers, and transaction details must be protected so that attackers cannot view or steal them.
- **Example (Social Media):** Private messages and personal details should not be accessible to unauthorized users.

Common mechanisms used to maintain confidentiality include encryption, authentication, and access control.

b) Integrity

Integrity ensures that data is accurate, consistent, and not altered by unauthorized entities.

- **Example (Banking):** Transaction amounts should not be modified during transfer.
- **Example (Social Media):** User profiles and posts should not be altered by attackers.

Techniques such as hashing, checksums, and digital signatures are used to ensure integrity.

c) Availability

Availability ensures that systems and data are accessible to authorized users when needed.

- **Example (Banking):** Online banking services should remain accessible 24/7.
- **Example (Social Media):** Platforms like WhatsApp or Instagram should be available without frequent downtime.

2. Types of Attackers

Understanding attacker profiles helps in designing effective defense strategies.

a) Script Kiddies

Script kiddies are inexperienced attackers who use ready-made tools and scripts without deep technical knowledge. They often target systems for fun or recognition.

b) Insiders

Insiders are employees, contractors, or trusted individuals who misuse their authorized access. Insider attacks are dangerous because they already have legitimate system access.

c) Hacktivists

Hackers perform cyber attacks to promote political, social, or ideological causes. Common activities include website defacement, data leaks, and DDoS attacks.

d) Nation-State Actors

These are highly skilled attackers sponsored by governments. Their objectives include espionage, surveillance, infrastructure disruption, and cyber warfare.

3. Attack Surface Overview

An **attack surface** is the total number of points where an attacker can attempt to enter or extract data from a system.

Common attack surfaces include:

- **Web Applications:** Login forms, input fields, file uploads, authentication mechanisms
- **Mobile Applications:** Insecure storage, weak authentication, improper API usage
- **APIs:** Broken authentication, excessive data exposure, improper access control
- **Networks:** Open ports, misconfigured firewalls, insecure protocols
- **Cloud Infrastructure:** Misconfigured storage buckets, weak IAM policies, exposed services

Reducing the attack surface is a key goal of cyber security.

4. OWASP Top 10 Vulnerabilities

OWASP Top 10 is a widely accepted list of the most critical web application security risks.

Some major OWASP Top 10 vulnerabilities include:

- **Injection:** Attackers inject malicious code (SQL, OS commands) through input fields.
- **Broken Authentication:** Weak login mechanisms allow attackers to impersonate users.
- **Sensitive Data Exposure:** Lack of encryption leads to data leaks.
- **Security Misconfiguration:** Default settings or misconfigured servers expose systems.
- **Cross-Site Scripting (XSS):** Malicious scripts executed in users' browsers.
- **Broken Access Control:** Users gain unauthorized access to restricted resources.

These vulnerabilities are dangerous because they can lead to data theft, account compromise, or full system takeover.

5. Mapping Daily-Used Applications to Attack Surfaces

Application	Possible Attack Surfaces
Email	Phishing links, malware attachments, weak passwords
WhatsApp	Malicious links, account takeover, insecure backups

Application Possible Attack Surfaces

Banking Apps Credential theft, insecure APIs, malware

Cloud Storage Misconfigured permissions, data leakage

6. Data Flow in a Typical Application

A standard data flow in an application is:

User → Application → Server → Database → Server → Application → User

1. User Layer (Presentation)

- **Action:** The process begins when a user interacts with a device, such as by entering text into a form or clicking a "Submit" button in a browser or mobile app.
- **Processing:** The application's front-end (built with technologies like React, Vue, or Swift) captures this input, validates it locally to ensure it is in the correct format, and packages it into a request.

2. Application Layer (Network/Client-Side)

- **Transmission:** The application sends the data across the internet, typically as an **HTTP request** (often in JSON format).
- **Gateways:** Before reaching the main server, the request may pass through a **Load Balancer**, which distributes traffic to maintain system performance, or a **CDN** (Content Delivery Network) for faster delivery.

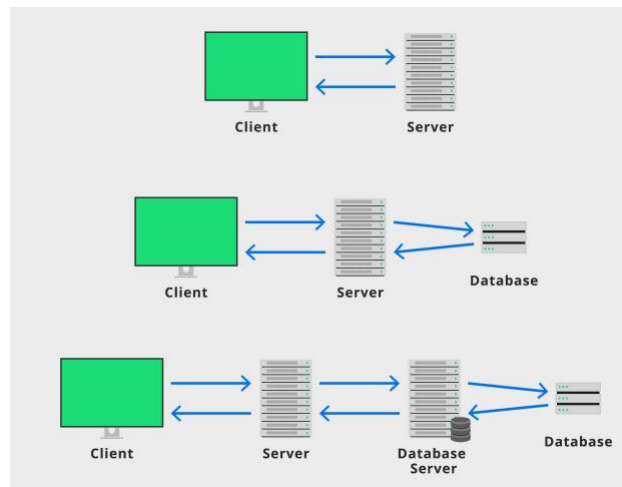
3. Server Layer (Business Logic)

- **Reception:** An application server (running Node.js, Python, or Java) receives the request and performs **Business Logic**.
- **Functions:**
 - **Authentication:** Verifies the user's identity and permissions.
 - **Transformation:** Processes or calculates the data as required by the app's rules.
 - **API Calls:** May interact with third-party services (e.g., payment processors or social logins) before proceeding.

4. Database Layer (Data Access/Storage)

- **Data Access Layer (DAL):** The server uses a specialized interface to communicate with the database, ensuring it does not have direct, raw access for security reasons.
- **CRUD Operations:** The server executes a database query—such as an SQL command for relational databases (MySQL, PostgreSQL) or a NoSQL command for document-based systems (MongoDB)—to Create, Read, Update, or Delete information.
- **Persistence:** The data is permanently stored on physical or cloud-based storage infrastructure, completing the flow.

Once stored, the server sends a **response** back through the same layers to inform the user that the action was successful



7. Attack Points in Data Flow

Attacks can occur at multiple stages:

- **User Side:** Phishing, keylogging, malware
- **Application Layer:** XSS, input validation flaws
- **Server Layer:** Authentication bypass, misconfigurations
- **Database Layer:** SQL injection, unauthorized access
- **Network Layer:** Man-in-the-middle (MITM) attacks

8. Summary

This task helped me understand the basic concepts of cyber security. I learned about the CIA triad and why confidentiality, integrity, and availability are important for protecting information. By studying different types of attackers and attack surfaces, I understood how applications can be attacked in real life. Learning about common vulnerabilities, especially from the OWASP Top 10, showed me where security risks usually occur. By mapping daily-used applications and understanding data flow, I could see where attacks might happen. Overall, this task gave me a basic understanding of how cyber security works and why it is important.

